CYPROS TECHNOLOGIES PVT. LTD.
A Cert-in Empanelled Company

Chhattisgarh Medical Services Corporation Limited

EMIS Application

Web Application Penetration Testing Report - Phase 1

Report Release Date	28 August 2026
AMBAK ID	AUD202608125584
Type of Audit	Web Application Penetration Testing Report – Phase 1
Asset URL	https://cgmsc.gov.in/emsa/
Testing Environment	Staging - Gray Box
Period	26 August 2026 to 28 August 2026
Classification	Confidential

Disclaimer: This confidential information is being provided to Chhattisgarh Medical Services Corporation Limited as a deliverable of the web application penetration testing. The purpose of this report is to provide recommendations regarding the vulnerabilities identified during the web application penetration testing. Each recipient agrees that the recipient shall not distribute or use the information contained herein and any other information regarding Cypros Technologies Private Limited for any purpose other than those stated.

Reg. Office: GR Samriddhi, No.273, 1st Floor, 7th Cross, Basavanapura Main Rd, near Silicon City College, Krishnarajapuram, Bengaluru, Karnataka – 560036.
www.cypros.in | info@cypros.in |+91 9964722968 / +91 9742353695 / +91 9538591980
GSTIN: 29AALCC5153A1ZT CIN: U69201KA2023PTC182363

Document Control

Document Details	
Document Title	Web Application Penetration Testing for Chhattisgarh Medical Services Corporation Limited - EMIS Application
Document ID	CY-DI260828482-01
Document Version	v1.0 – Initial Report
Prepared By	Chaitrali
Reviewed By	Gnanesh G
Approved By	P Rakesh Shenoy
Released By	Nagaraja M
Release Date	28 August 2026

Document Change History		
Version	**Date**	**Remarks / Reason for change**
v1.0	28 August 2026	Initial Phase

Document Distribution List			
Name	**Organization**	**Designation**	**Email ID**
Sukhdev Kashyap	Chhattisgarh Medical Services Corporation Limited	System Manager	it.cgmsc@gov.in

Table of Contents

1. Introduction 4
2. Engagement Scope 4
3. Details of the Auditing team 4
4. Audit activities and Timelines 5
5. Audit Methodology and Criteria / Standard referred for audit 5
6. Tools and Software's used 5
7. Vulnerability Severity Legend 6
8. Executive Summary 6
   8.1 Technical Details 6
   8.2 Vulnerabilities distribution 9
9. Detailed Observations 10

1. Introduction

Cypros Technologies Pvt. Ltd. conducted a Web Application Penetration Testing to assess the security posture of the target web application and identify vulnerabilities that could be exploited by potential attackers. The objective of this assessment was to evaluate the effectiveness of existing security controls and provide actionable recommendations to enhance the application's overall resilience against cyber threats.

Cypros Technologies Pvt. Ltd. is empaneled by CERT-In under the Ministry of Electronics and Information Technology (MeitY), Government of India. CERT-In serves as the national nodal agency for responding to cybersecurity incidents, coordinating response measures, and strengthening the overall cybersecurity framework across India.

The assessment was conducted in accordance with globally recognized security frameworks and standards such as CERT-In guidelines, OWASP Top 10, with references to ISO/IEC 27001 and ISACA auditing guidelines. A combination of black-box and gray-box testing approaches was adopted to simulate realistic attack scenarios and ensure comprehensive vulnerability identification and validation. The results of this engagement provide valuable insights to improve application security and align it with established industry and regulatory best practices.

2. Engagement Scope

The Engagement Scope lists the applications covered, including their URLs, hash values, and versions.

SN	Asset Description	Application URL	MD5 Value	SHA Value	Application Version
1.	Web Application	https://cgmsc.gov.in/emsa/	8FDDF26A3F8BD98258FEC9D2B3B4624A	6E29E97C05BC0443268EEB090A55717D7A3930462B85FAD5E017957B71013E13	1.0

3. Details of the Auditing team

SN	Name	Designation	Email ID	Professional Qualifications /Certifications	Whether the resource listed in the snapshot information published on CERT-In's website (Yes/No)
1.	Ananya N	Security Engineer	Ananya.akirekad@cypros.in	MSc, CEH	Yes

4. Audit activities and Timelines

The Web Application Penetration Testing was carried out in a phased manner to ensure comprehensive coverage and accuracy. The key audit activities and corresponding timelines are as follows:

Phase	Description	Timeline		Remarks
		From	To	
Phase-1	Initial Assessment	26 August 2026	28 August 2026	--
Phase-2	Final Assessment	--	--	--

5. Audit Methodology and Criteria / Standard referred for audit

The Web Application Penetration Testing was carried out using a combination of manual testing and automated tools, following industry best practices and standards such as the CERT-In guidelines, OWASP Top 10, and NIST SP 800-115.

- **Automated Testing**

  We used automated tools to scan the web application for known security issues. This helped quickly find possible weaknesses, wrong configurations, and outdated software components in the system.

- **Manual Testing**

  After the automated scan, we performed manual testing to check and confirm the results. Our team used their experience in web application security to find deeper issues, coding mistakes, and logic flaws that automated tools might miss.

- **Test cases and Standards**

  All test cases and attack scenarios were designed and executed mainly following the CERT-In security assessment guidelines. In addition, recognized industry standards and best practices such as OWASP Top 10, SANS 25 and NIST SP 800-15 were also referred to. This ensured a thorough and standards-based evaluation of the web application's security

6. Tools and Software's used

SN	Name of Tool / Softwares used	Version of the tool / Softwares used	Open Source / Licensed
1.	Burp Suite Professional	v.2025.1.1	Licensed
2.	Kali Linux	v.2025.3	Open Source

7. Vulnerability Severity Legend

Severity	Description
Critical	This severity level represents a critical weakness in the current control environment which could be exploited easily and requires management's immediate consideration and action to meet minimum control standards.
High	This severity level represents a significant weakness in the current control environment and requires management's immediate consideration and action to meet minimum control standards.
Medium	This level of vulnerability represents a moderate level of weakness in the current control environment and requires management action attention in the near term.
Low	This severity level provides for an opportunity to improve effectiveness and efficiency of the current control environment.
Info	This severity level represents an informational observation that is shared to provide insights or best-practice recommendations. Mitigating this issue will improve the application's overall security posture.

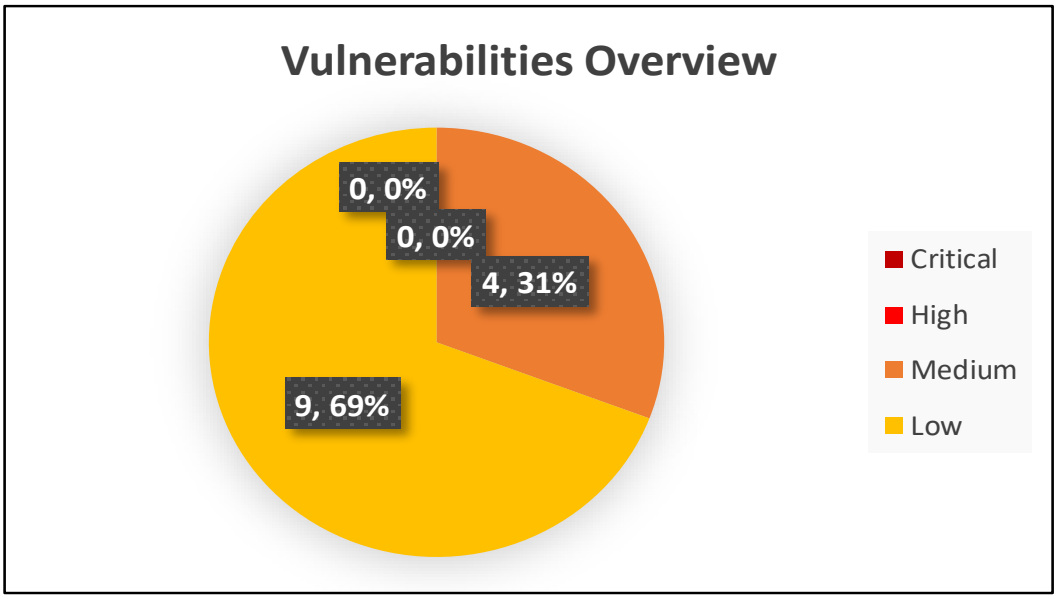
Note: Vulnerability severity is determined considering the leading security practices and past experience of Cypros assessors in executing similar projects.

8. Executive Summary

A web application penetration testing was carried out to assess the security strength of the target application against potential cyberattacks. The assessment simulated real-world attack techniques within the defined scope to identify existing threats and vulnerabilities. The objective was to evaluate the application's resilience and provide actionable recommendations to enhance its overall security posture.

A summary of vulnerabilities that have been discovered while performing web application penetration testing are given below.

Critical	High	Medium	Low	Total
0	0	4	9	13



8.1 Technical Details

SN	Vulnerability Name	Affected URL/ IP	CVE/CWE	Severity	Status
1	Cross-Origin-Resource-Sharing (CORS) misconfiguration	https://cgmsc.gov.in/emsapi/api/Auth/login1	CWE-942	Medium	Open
2	Clickjacking	https://cgmsc.gov.in/emsa/	CWE-1021	Medium	Open
3	XSS via file upload	https://cgmsc.gov.in/EMIS/reports/eel-specification	CWE-79	Medium	Open
4	Downgrade attack possible	https://cgmsc.gov.in/emsa/	CWE-757	Medium	Open
5	Server version disclosure	https://cgmsc.gov.in/emsa/	CWE-200	Low	Open
6	Content-Security-Policy (CSP) header missing	https://cgmsc.gov.in/emsa/	CWE-693	Low	Open
7	X-Content-Type-Options header missing	https://cgmsc.gov.in/emsa/	CWE-693	Low	Open
8	Weak CBC mode ciphers	https://cgmsc.gov.in/emsa/	CWE-327	Low	Open
9	Weak TLS ciphers	https://cgmsc.gov.in/emsa/	CWE-327	Low	Open
10	Concurrent login	https://cgmsc.gov.in/EMIS/welcome	CWE-287	Low	Open
11	HTTP Strict-Transport-Security (HSTS) header missing	https://cgmsc.gov.in/emsa/	CWE-693	Low	Open
12	Improper CAPTCHA validation	https://cgmsc.gov.in/EMIS/login	CWE-804	Low	Open
13	Unrestricted file upload	https://cgmsc.gov.in/EMIS/reports/eel-specification	CWE-434	Low	Open
14	HTTP OPTIONS method enabled	https://cgmsc.gov.in/emsa/	CWE-200	Info	Open

SN	Vulnerability Name	Affected URL/ IP	CVE/CWE	Severity	Status
15	Improper input validation	https://cgmsc.gov.in/EMIS/IT/add-sub-menu https://cgmsc.gov.in/EMIS/StoreHome	CWE-20	Info	Open

8.2 Vulnerabilities distribution

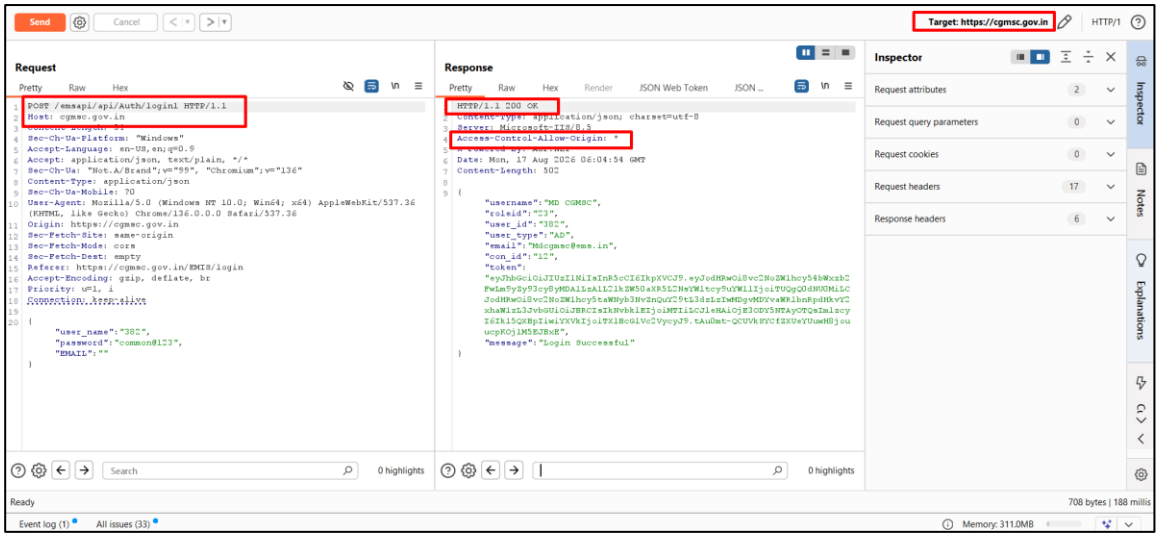
All set of applicable OWASP Top 10 Security Threats.

Criteria Label	Status	Vulnerability Findings
A01:2021-Broken Access Control	**Meets Criteria**	No Findings
A02:2021-Cryptographic Failures	**Fails Criteria**	• Weak CBC mode ciphers • Weak TLS ciphers • Downgrade attack possible
A03:2021-Injection	**Fails Criteria**	• Improper input validation • XSS via file upload
A04:2021-Insecure Design	**Meets Criteria**	No Findings
A05:2021-Security Misconfiguration	**Fails Criteria**	• Cross-Origin-Resource-Sharing (CORS) misconfiguration • Clickjacking • Server version disclosure • Content-Security-Policy (CSP) header missing • X-Content-Type-Options header missing • HTTP Strict-Transport-Security (HSTS) header missing • Unrestricted file upload • HTTP OPTIONS method enabled
A06:2021-Vulnerable and Outdated Components	**Meets Criteria**	No Findings
A07:2021-Identification and Authentication Failures	**Fails Criteria**	• Concurrent login • Improper CAPTCHA validation
A08:2021-Software and Data Integrity Failures	**Meets Criteria**	No Findings
A09:2021-Security Logging and Monitoring Failures	**Meets Criteria**	No Findings
A10:2021-Server-Side Request Forgery (SSRF)	**Meets Criteria**	No Findings

9. Detailed Observations

Vulnerability Point No. 1	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/emsapi/api/Auth/login1
Vulnerability Name	Cross-Origin-Resource-Sharing (CORS) misconfiguration
CWE/CVE	CWE-942
Severity	**Medium**
Status	**Open**
Description	The application has an overly permissive CORS configuration that allows requests from untrusted or arbitrary origins. This can result from using wildcard origins or improper validation of the Origin header.
Impact	An attacker may exploit this issue to access sensitive data or perform unauthorized actions using a victim's authenticated session. This increases the risk of data theft and cross-site attacks.
Recommendation	CORS policies should be restricted to trusted and explicitly whitelisted domains only. Wildcard origins must be avoided, especially when credentials are enabled.
Proof of Concept	

Note: The below POC shows Cross-Origin-Resource-Sharing (CORS) misconfiguration issue.



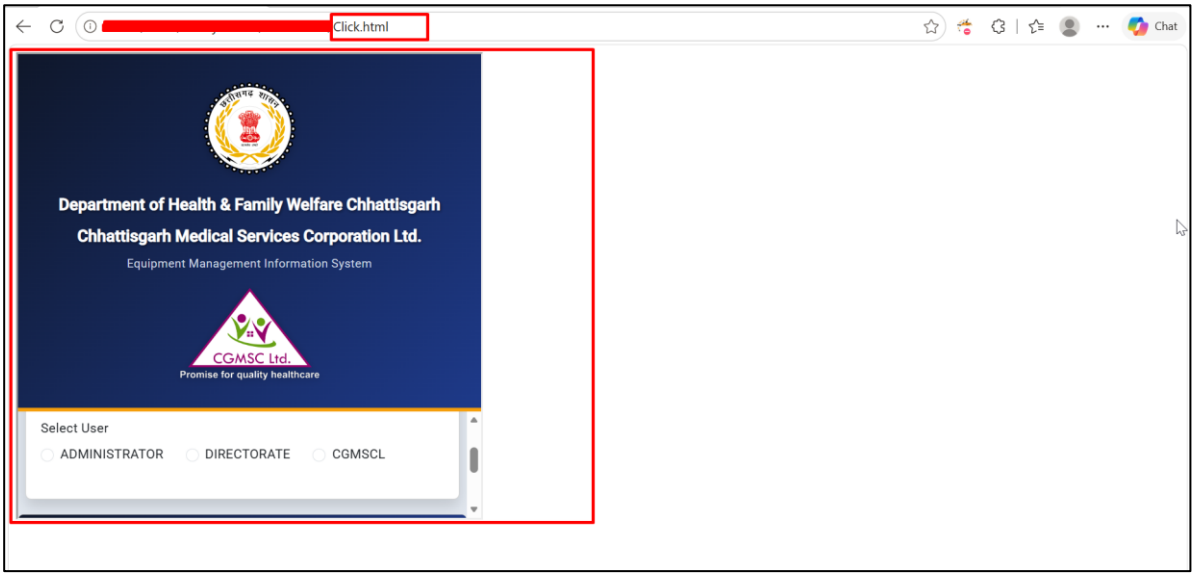
Vulnerability Point No. 2	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/emsa/
Vulnerability Name	Clickjacking
CWE/CVE	CWE-1021
Severity	Medium
Status	Open
Description	The application does not implement clickjacking protection due to the absence of the X-Frame-Options header or equivalent controls, allowing pages to be embedded in iframe on malicious websites.
Impact	Attackers may trick users into performing unintended actions, such as submitting forms or changing settings, leading to potential compromise of user integrity and sensitive data.
Recommendation	Implement the X-Frame-Options header with DENY or SAMEORIGIN, or enforce CSP frame-ancestors, across all sensitive application pages.

Proof of Concept

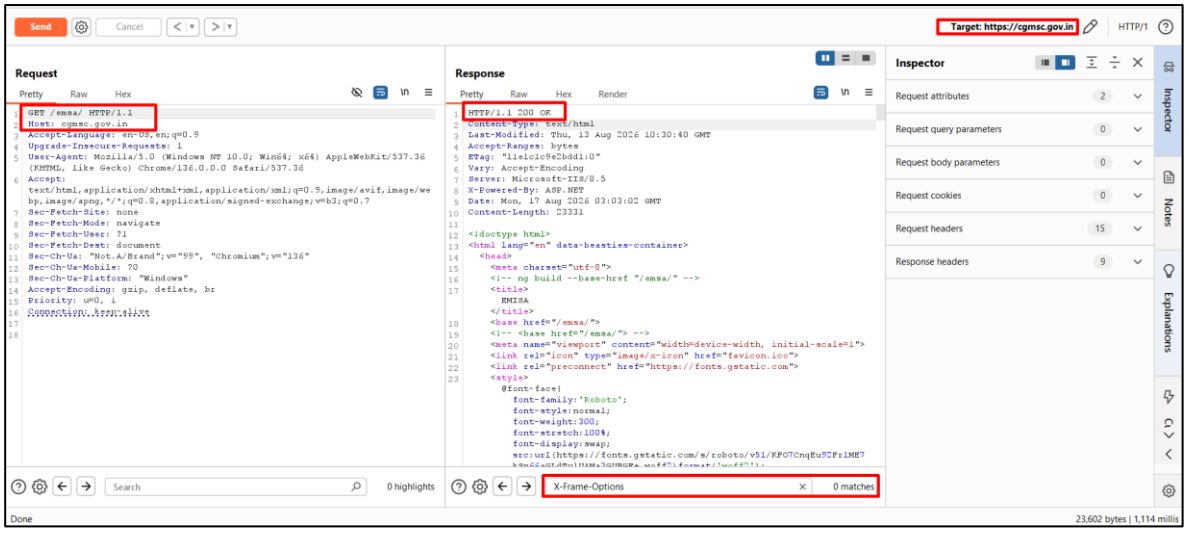
Note: The below POC shows the clickjacking issue.

```
<html>
<head>
<title>clickjacking</title>
</head>
<body>
<iframe src="https://cgmsc.gov.in/emsa" width="1000" height="500"></iframe>
</body>
</html>
```

POC 1 – Embedded the target application (https://cgmsc.gov.in/emsa/) inside an <iframe> to test for clickjacking protection.



POC 2 - The application loaded successfully inside the <iframe>, demonstrating the absence of clickjacking protection.

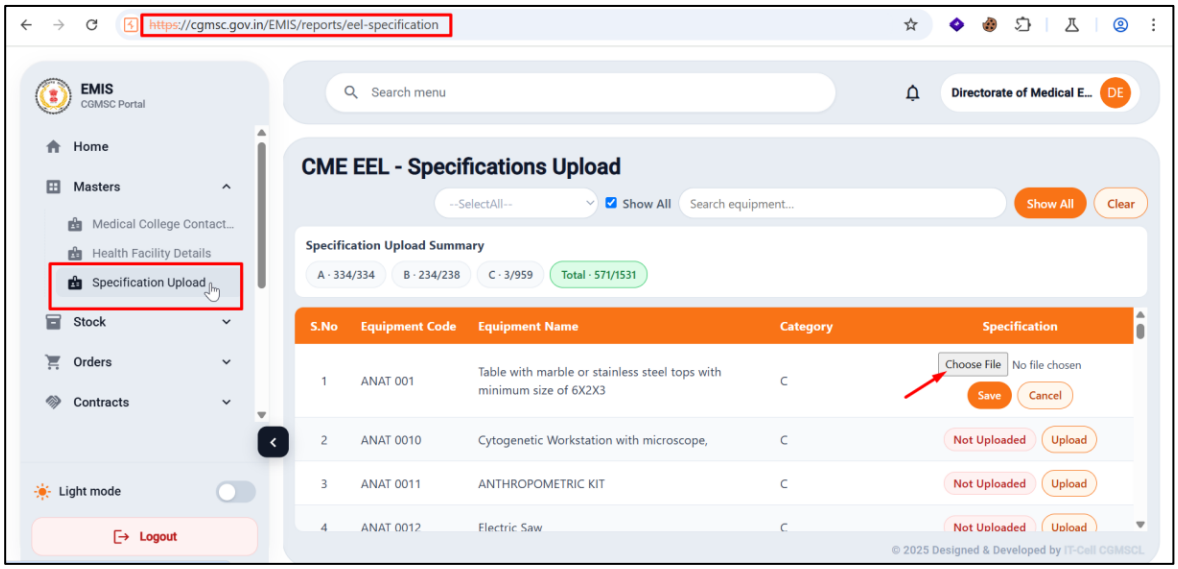


POC 3 - X-Frame-Options header is missing

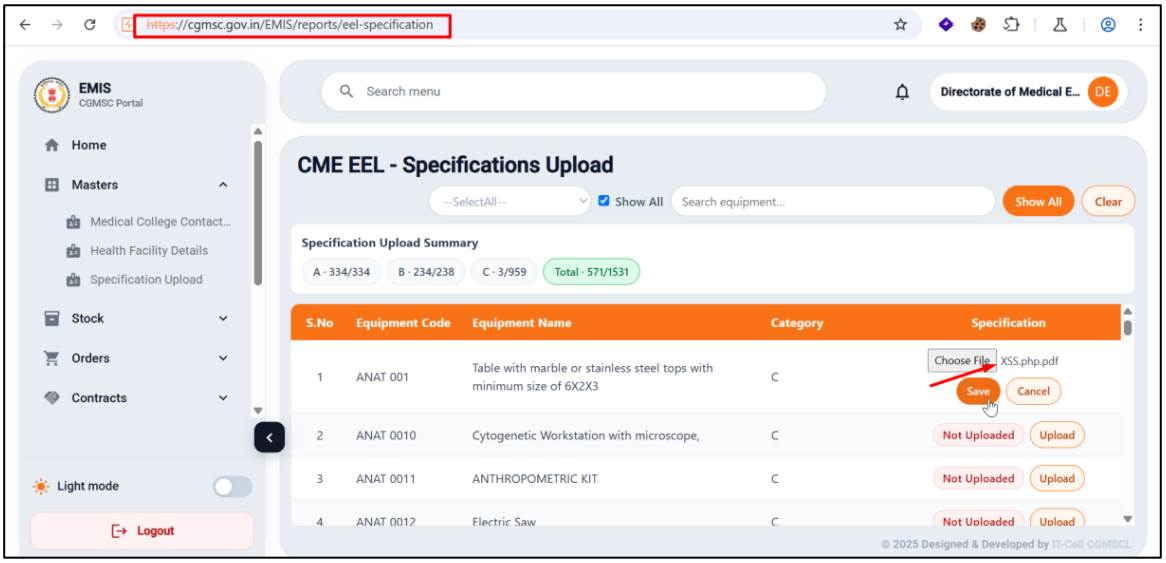
Vulnerability Point No. 3	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/EMIS/reports/eel-specification
Vulnerability Name	XSS via file upload
CWE/CVE	CWE-79
Severity	Medium
Status	Open
Description	The application allows users to upload files without properly validating the file content, enabling attackers to upload files containing malicious scripts that execute when the file is opened.
Impact	Attackers can execute malicious JavaScript in the victim's browser, leading to session hijacking, data theft, or account takeover.
Recommendation	Implement strict file validation, sanitize uploaded content, and ensure uploaded files are served with safe content types to prevent script execution.
Proof of Concept	

Note: The below POC shows that the uploaded PDF contains an XSS payload which executes when the file is opened.

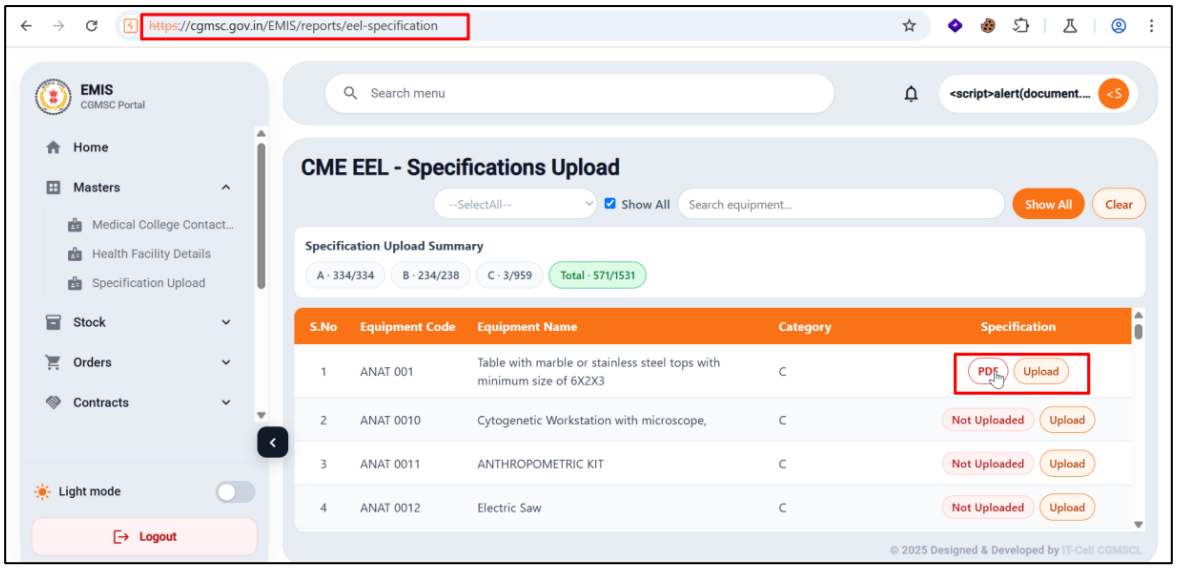
The identified XSS via File Upload issue is applicable to the file upload functionality under the Admin role when the Directorate is selected as CIMS Medical College.



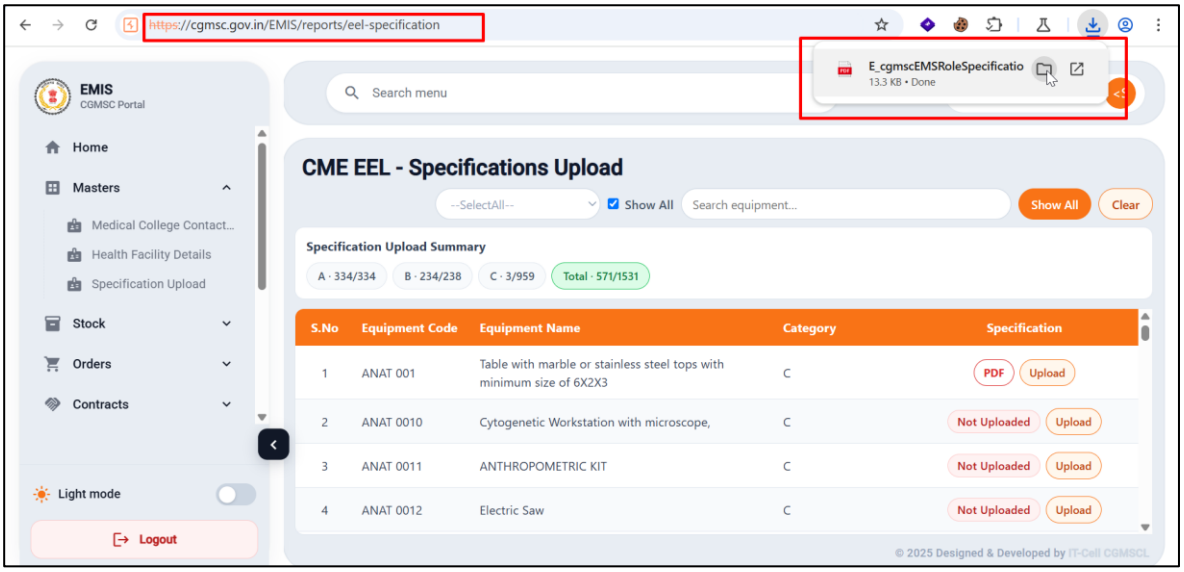
POC 1 - Navigate to Masters → Specification Upload and click Choose File for the required equipment specification.



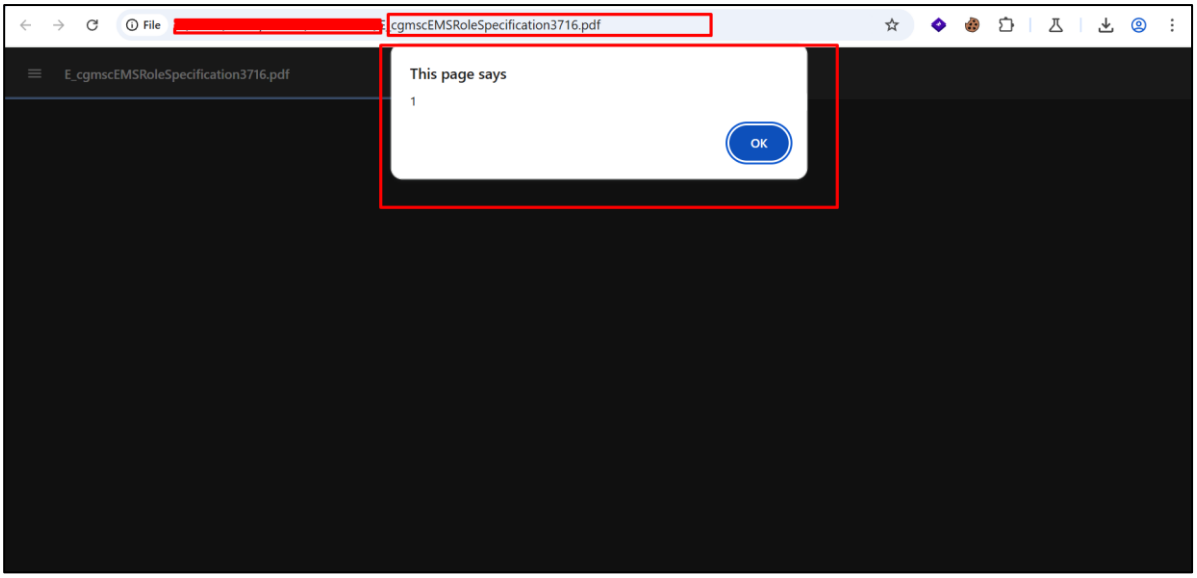
POC 2 - Upload the XSS.php.pdf file using the Choose File option and click Save.



POC 3 - Click the uploaded XSS.php.pdf file (PDF option) to download the file.



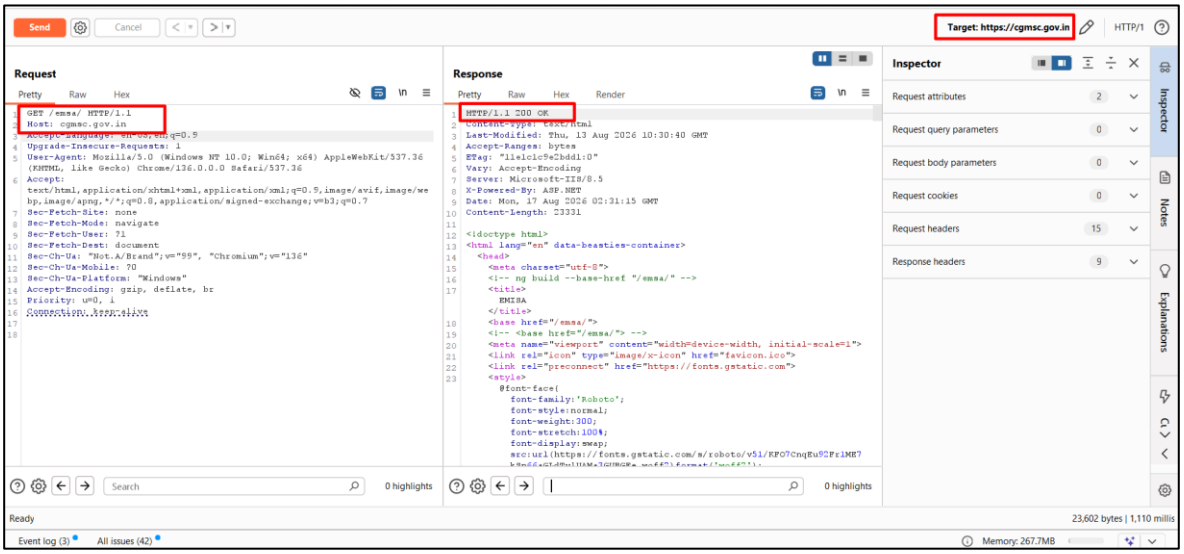
POC 4 - The file is downloaded successfully.



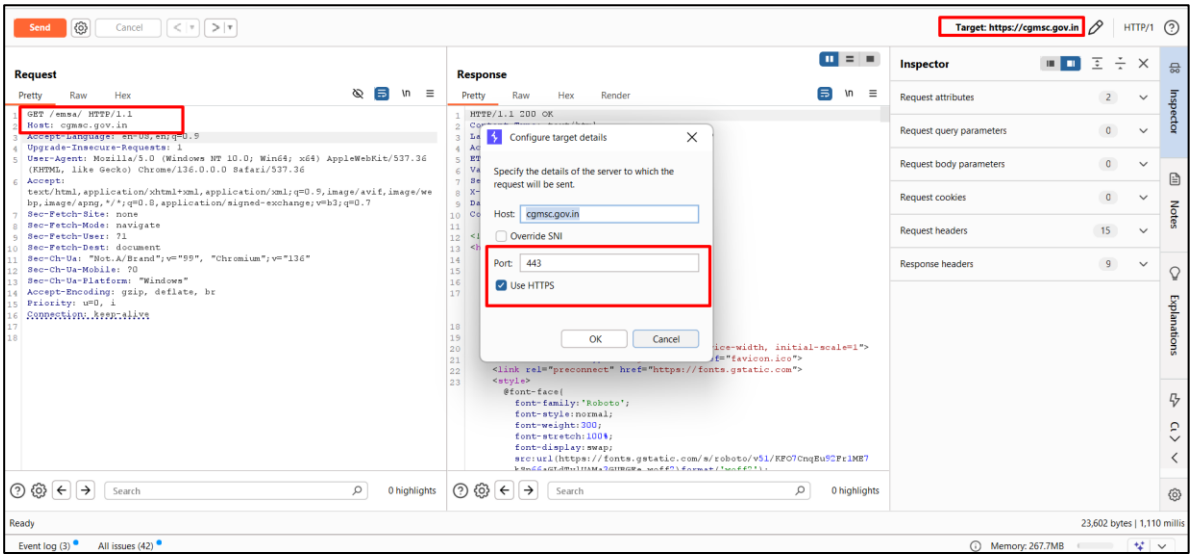
POC 5 - The uploaded PDF executes the injected script when opened.

Vulnerability Point No. 4	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/emsa/
Vulnerability Name	Downgrade attack possible
CWE/CVE	CWE-757
Severity	Medium
Status	Open
Description	The system allows negotiation of weaker or legacy security protocols during communication, making it possible for an attacker to force a downgrade to less secure encryption methods.
Impact	An attacker may exploit this weakness to perform man-in-the-middle attacks, potentially compromising the confidentiality and integrity of data transmitted between the client and server.
Recommendation	The application should enforce strong and modern TLS versions, disable outdated protocols and cipher suites, and ensure secure protocol negotiation to prevent downgrade attacks.
Proof of Concept	

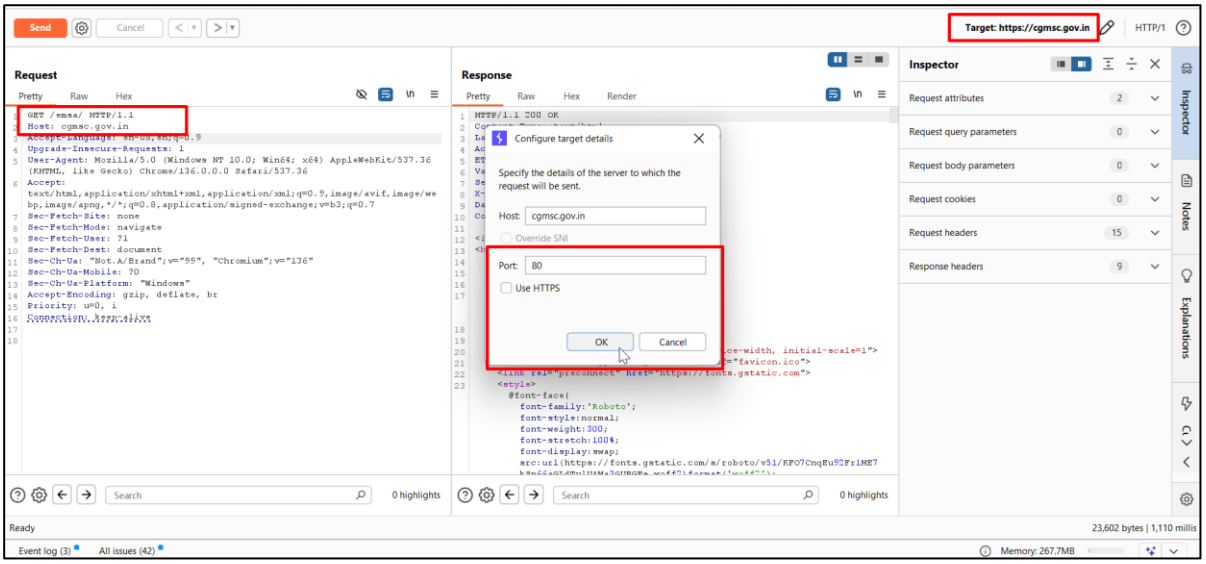
Note: The below POC shows that the application supports weak security protocols.



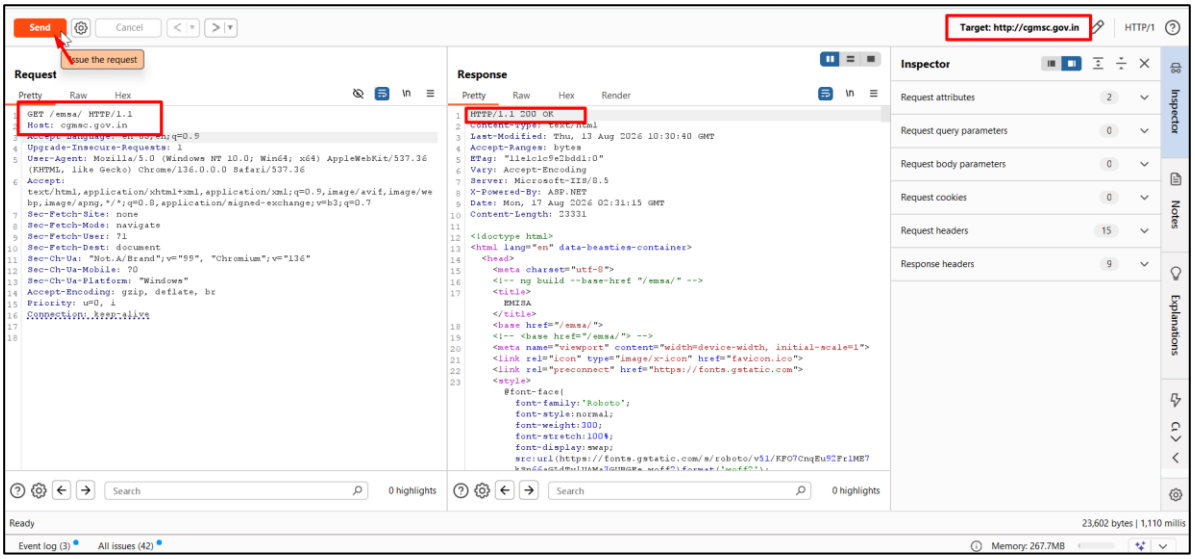
POC 1 - Capture a valid https request in Burp Suite and send it to Repeater. Verify that the request is successfully processed over https.



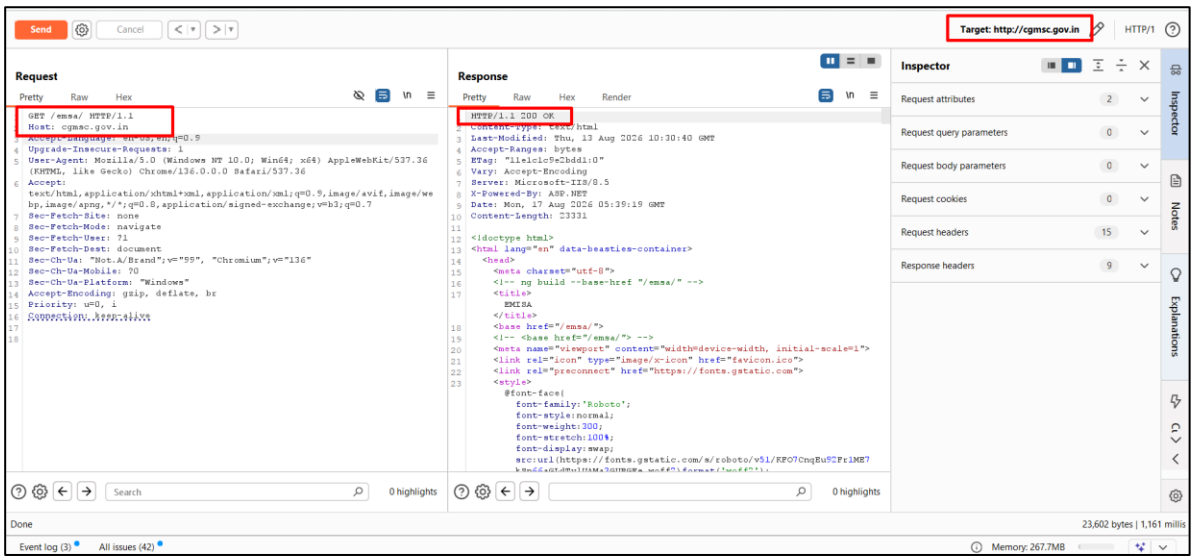
POC 2 - The application uses HTTPS and runs on port 443.



POC 3 - In Configure Target Details, uncheck the Use HTTPS option and resend the same request over http.



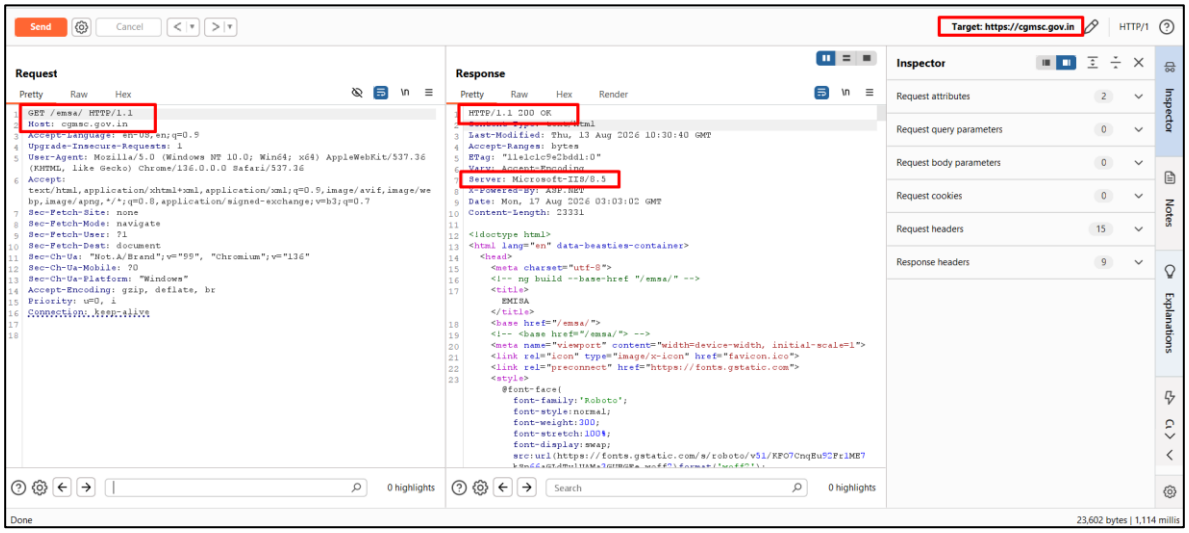
POC 4 – Send the request.



POC 5 - After changing the request to HTTP, the application successfully processed the request over HTTP.

Vulnerability Point No. 5	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/emsa/
Vulnerability Name	Server version disclosure
CWE/CVE	CWE-200
Severity	Low
Status	Open
Description	The server reveals version information through HTTP headers or error messages.
Impact	Attackers may use version details to identify known vulnerabilities.
Recommendation	Remove or obfuscate server version information from responses and headers.
Proof of Concept	

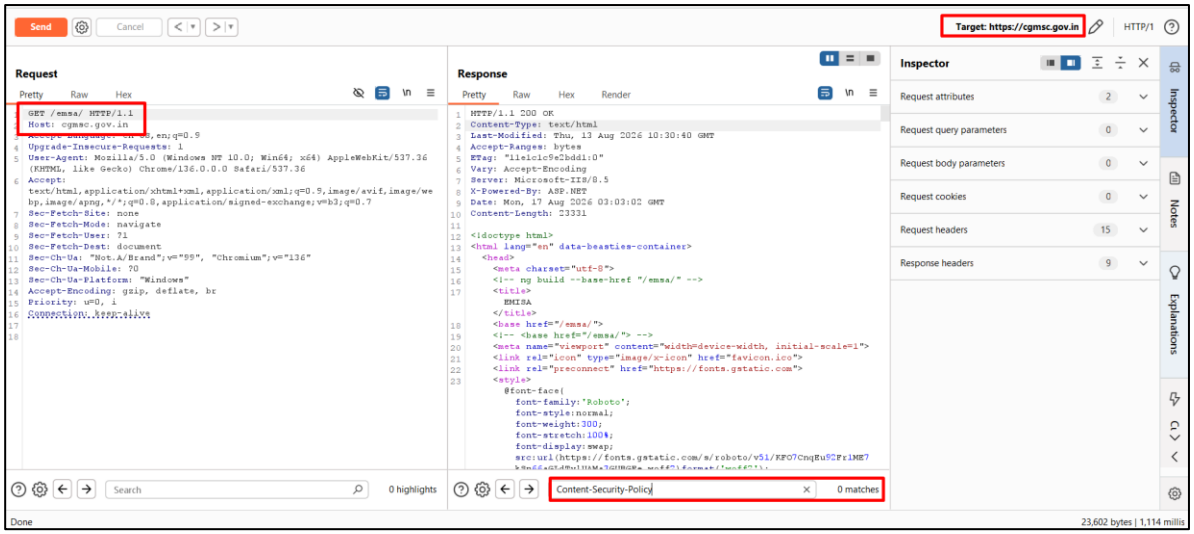
Note: The below POC shows that server version is disclosed.



POC 1 - Microsoft-IIS version 8.5 is disclosed.

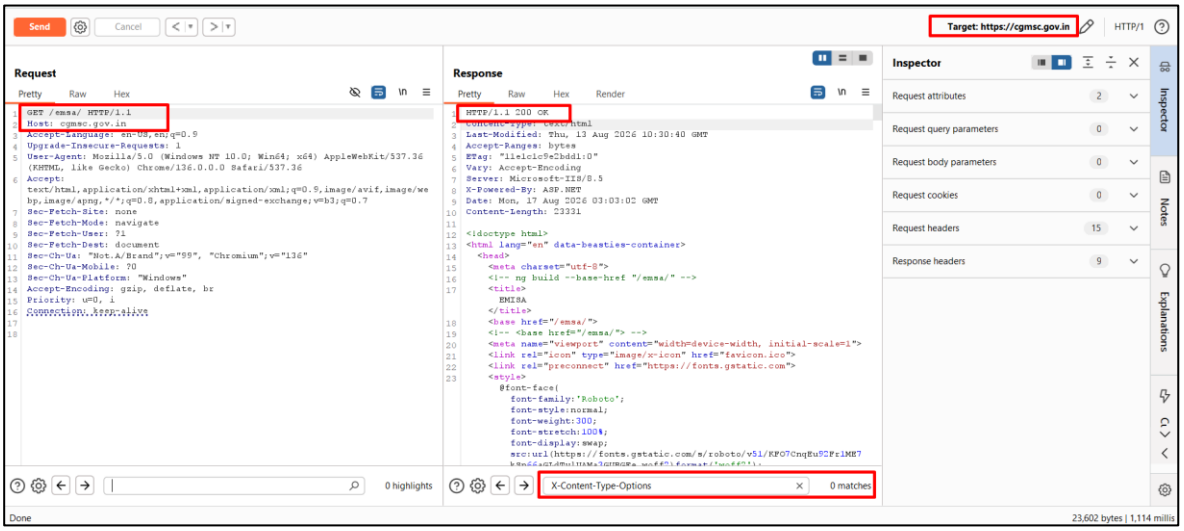
Vulnerability Point No. 6	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/emsa/
Vulnerability Name	Content-Security-Policy (CSP) header missing
CWE/CVE	CWE-693
Severity	**Low**
Status	**Open**
Description	The application does not implement a Content-Security-Policy (CSP) header. Without CSP, the browser cannot restrict the sources of scripts, styles, or other resources.
Impact	This increases the risk of client-side attacks, such as Cross-Site Scripting (XSS) or injection of malicious content.
Recommendation	Implement a strict Content Security Policy header to control which sources are allowed to load scripts, styles, images, and other resources.
Proof of Concept	

Note: The below POC shows that Content-Security-Policy (CSP) header is missing.



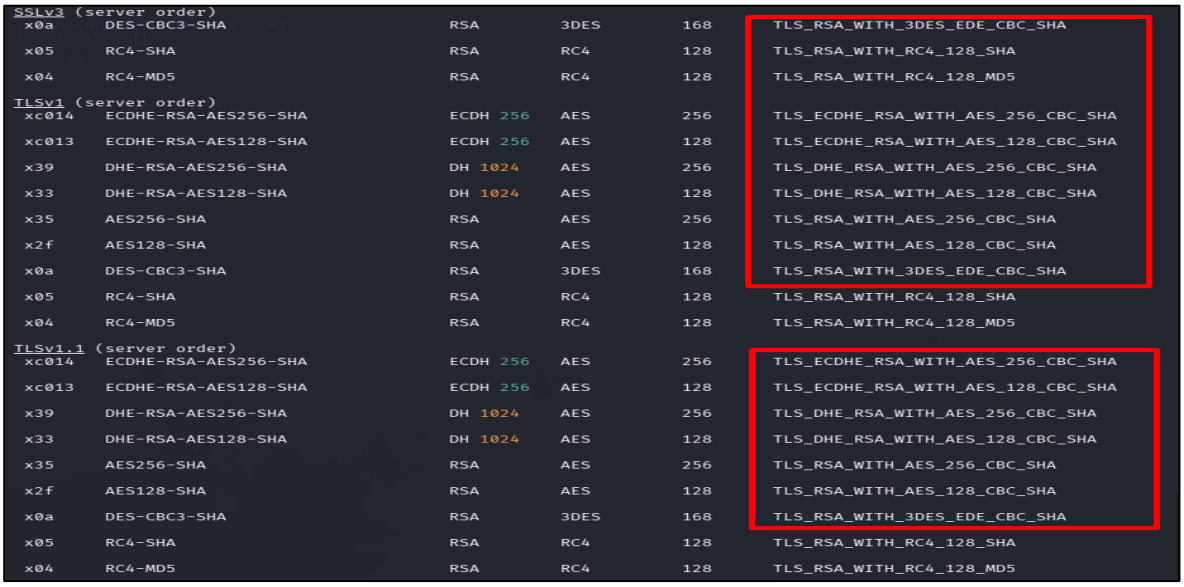
Vulnerability Point No. 7	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/emsa/
Vulnerability Name	X-Content-Type-Options header missing
CWE/CVE	CWE-693
Severity	**Low**
Status	**Open**
Description	The application does not set the X-Content-Type-Options: nosniff header. Without it, browsers may incorrectly interpret files and execute them as a different MIME type
Impact	This can allow attackers to bypass content type restrictions, potentially leading to XSS or execution of malicious content.
Recommendation	Set the X-Content-Type-Options: nosniff header for all responses to prevent MIME type sniffing.
Proof of Concept	

Note: The below POC shows that X-Content-Type-Options header is missing.

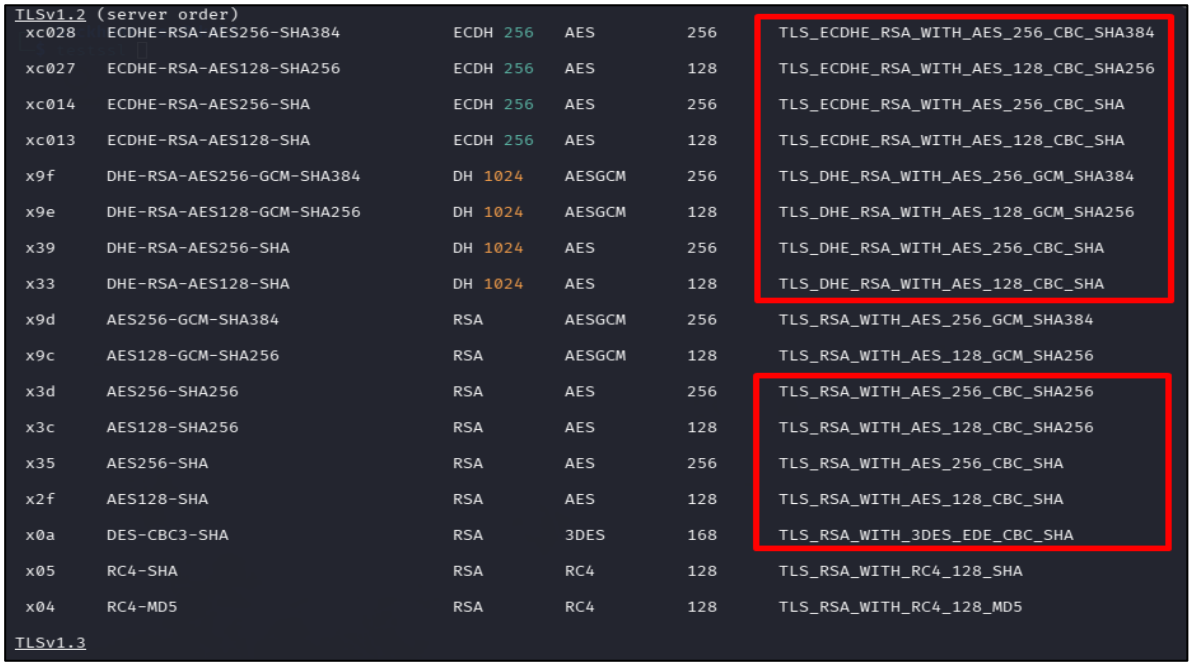


Vulnerability Point No. 8	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/emsa/
Vulnerability Name	Weak CBC mode ciphers
CWE/CVE	CWE-327
Severity	**Low**
Status	**Open**
Description	The server supports weak CBC-mode cipher suites that are known to be vulnerable to cryptographic attacks.
Impact	Attackers may exploit these weaknesses to decrypt sensitive information or compromise the confidentiality of encrypted communications.
Recommendation	Weak cipher suites should be disabled and replaced with strong, modern encryption algorithms such as AES-GCM or ChaCha20 following industry best practices.
Proof of Concept	

Note: The below POC shows Weak CBC mode ciphers.

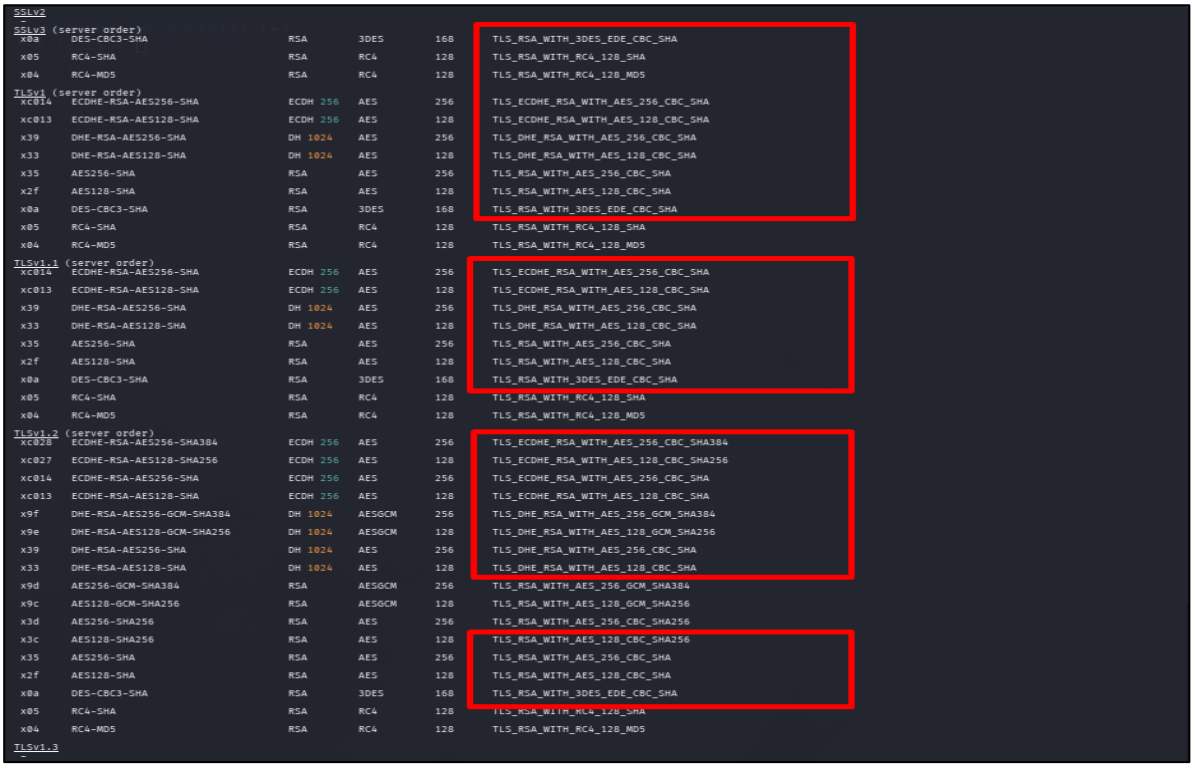


POC 1 - The above POC shows that weak CBC ciphers are used.



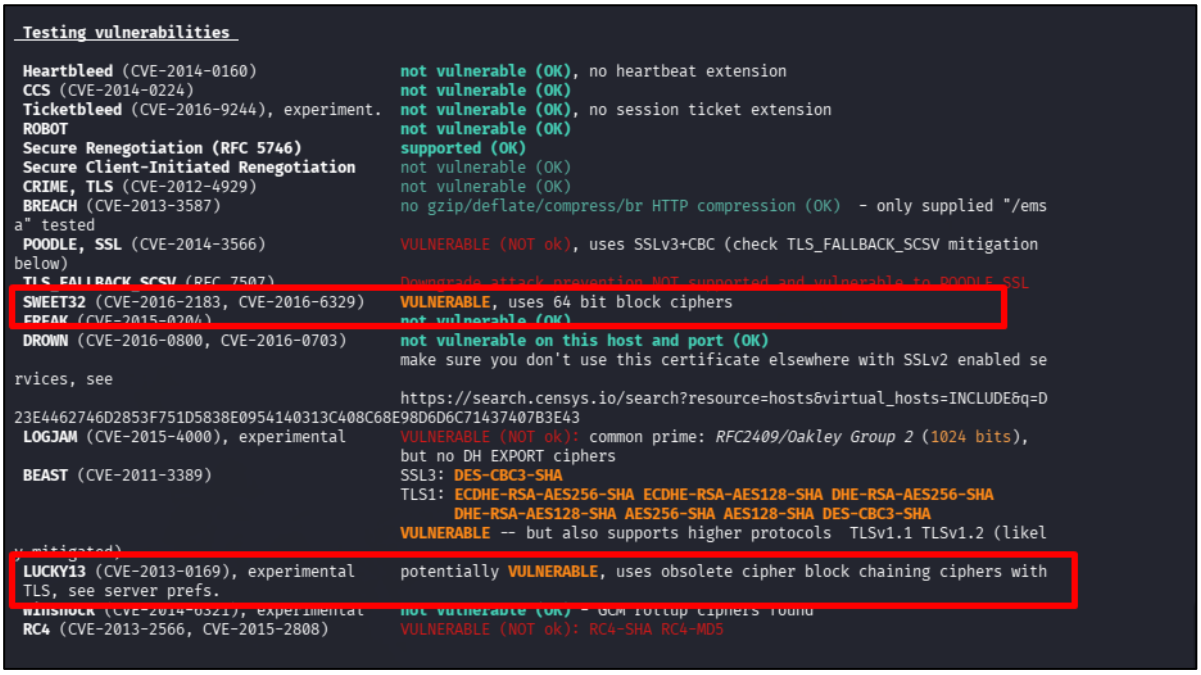
TLSv1.2 (server order)					
xc028	ECDHE-RSA-AES256-SHA384	ECDH 256	AES	256	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384
xc027	ECDHE-RSA-AES128-SHA256	ECDH 256	AES	128	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256
xc014	ECDHE-RSA-AES256-SHA	ECDH 256	AES	256	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA
xc013	ECDHE-RSA-AES128-SHA	ECDH 256	AES	128	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA
x9f	DHE-RSA-AES256-GCM-SHA384	DH 1024	AESGCM	256	TLS_DHE_RSA_WITH_AES_256_GCM_SHA384
x9e	DHE-RSA-AES128-GCM-SHA256	DH 1024	AESGCM	128	TLS_DHE_RSA_WITH_AES_128_GCM_SHA256
x39	DHE-RSA-AES256-SHA	DH 1024	AES	256	TLS_DHE_RSA_WITH_AES_256_CBC_SHA
x33	DHE-RSA-AES128-SHA	DH 1024	AES	128	TLS_DHE_RSA_WITH_AES_128_CBC_SHA
x9d	AES256-GCM-SHA384	RSA	AESGCM	256	TLS_RSA_WITH_AES_256_GCM_SHA384
x9c	AES128-GCM-SHA256	RSA	AESGCM	128	TLS_RSA_WITH_AES_128_GCM_SHA256
x3d	AES256-SHA256	RSA	AES	256	TLS_RSA_WITH_AES_256_CBC_SHA256
x3c	AES128-SHA256	RSA	AES	128	TLS_RSA_WITH_AES_128_CBC_SHA256
x35	AES256-SHA	RSA	AES	256	TLS_RSA_WITH_AES_256_CBC_SHA
x2f	AES128-SHA	RSA	AES	128	TLS_RSA_WITH_AES_128_CBC_SHA
x0a	DES-CBC3-SHA	RSA	3DES	168	TLS_RSA_WITH_3DES_EDE_CBC_SHA
x05	RC4-SHA	RSA	RC4	128	TLS_RSA_WITH_RC4_128_SHA
x04	RC4-MD5	RSA	RC4	128	TLS_RSA_WITH_RC4_128_MD5
TLSv1.3					

POC 2 - The above POC shows that weak CBC ciphers are used.



SSLv2					
SSLv3 (server order)					
x0a	DES-CBC3-SHA	RSA	3DES	168	TLS_RSA_WITH_3DES_EDE_CBC_SHA
x05	RC4-SHA	RSA	RC4	128	TLS_RSA_WITH_RC4_128_SHA
x04	RC4-MD5	RSA	RC4	128	TLS_RSA_WITH_RC4_128_MD5
TLSv1 (server order)					
xc014	ECDHE-RSA-AES256-SHA	ECDH 256	AES	256	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA
xc013	ECDHE-RSA-AES128-SHA	ECDH 256	AES	128	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA
x39	DHE-RSA-AES256-SHA	DH 1024	AES	256	TLS_DHE_RSA_WITH_AES_256_CBC_SHA
x33	DHE-RSA-AES128-SHA	DH 1024	AES	128	TLS_DHE_RSA_WITH_AES_128_CBC_SHA
x35	AES256-SHA	RSA	AES	256	TLS_RSA_WITH_AES_256_CBC_SHA
x2f	AES128-SHA	RSA	AES	128	TLS_RSA_WITH_AES_128_CBC_SHA
x0a	DES-CBC3-SHA	RSA	3DES	168	TLS_RSA_WITH_3DES_EDE_CBC_SHA
x05	RC4-SHA	RSA	RC4	128	TLS_RSA_WITH_RC4_128_SHA
x04	RC4-MD5	RSA	RC4	128	TLS_RSA_WITH_RC4_128_MD5
TLSv1.1 (server order)					
xc014	ECDHE-RSA-AES256-SHA	ECDH 256	AES	256	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA
xc013	ECDHE-RSA-AES128-SHA	ECDH 256	AES	128	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA
x39	DHE-RSA-AES256-SHA	DH 1024	AES	256	TLS_DHE_RSA_WITH_AES_256_CBC_SHA
x33	DHE-RSA-AES128-SHA	DH 1024	AES	128	TLS_DHE_RSA_WITH_AES_128_CBC_SHA
x35	AES256-SHA	RSA	AES	256	TLS_RSA_WITH_AES_256_CBC_SHA
x2f	AES128-SHA	RSA	AES	128	TLS_RSA_WITH_AES_128_CBC_SHA
x0a	DES-CBC3-SHA	RSA	3DES	168	TLS_RSA_WITH_3DES_EDE_CBC_SHA
x05	RC4-SHA	RSA	RC4	128	TLS_RSA_WITH_RC4_128_SHA
x04	RC4-MD5	RSA	RC4	128	TLS_RSA_WITH_RC4_128_MD5
TLSv1.2 (server order)					
xc028	ECDHE-RSA-AES256-SHA384	ECDH 256	AES	256	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384
xc027	ECDHE-RSA-AES128-SHA256	ECDH 256	AES	128	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256
xc014	ECDHE-RSA-AES256-SHA	ECDH 256	AES	256	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA
xc013	ECDHE-RSA-AES128-SHA	ECDH 256	AES	128	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA
x9f	DHE-RSA-AES256-GCM-SHA384	DH 1024	AESGCM	256	TLS_DHE_RSA_WITH_AES_256_GCM_SHA384
x9e	DHE-RSA-AES128-GCM-SHA256	DH 1024	AESGCM	128	TLS_DHE_RSA_WITH_AES_128_GCM_SHA256
x39	DHE-RSA-AES256-SHA	DH 1024	AES	256	TLS_DHE_RSA_WITH_AES_256_CBC_SHA
x33	DHE-RSA-AES128-SHA	DH 1024	AES	128	TLS_DHE_RSA_WITH_AES_128_CBC_SHA
x9d	AES256-GCM-SHA384	RSA	AESGCM	256	TLS_RSA_WITH_AES_256_GCM_SHA384
x9c	AES128-GCM-SHA256	RSA	AESGCM	128	TLS_RSA_WITH_AES_128_GCM_SHA256
x3d	AES256-SHA256	RSA	AES	256	TLS_RSA_WITH_AES_256_CBC_SHA256
x3c	AES128-SHA256	RSA	AES	128	TLS_RSA_WITH_AES_128_CBC_SHA256
x35	AES256-SHA	RSA	AES	256	TLS_RSA_WITH_AES_256_CBC_SHA
x2f	AES128-SHA	RSA	AES	128	TLS_RSA_WITH_AES_128_CBC_SHA
x0a	DES-CBC3-SHA	RSA	3DES	168	TLS_RSA_WITH_3DES_EDE_CBC_SHA
x05	RC4-SHA	RSA	RC4	128	TLS_RSA_WITH_RC4_128_SHA
x04	RC4-MD5	RSA	RC4	128	TLS_RSA_WITH_RC4_128_MD5
TLSv1.3					

POC 3 - The above POC shows that weak CBC ciphers are used.



POC 4 - The above POC shows that the application is vulnerable to SWEET32 and LUCKY13.

Vulnerability Point No. 9	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/emsa/
Vulnerability Name	Weak TLS ciphers
CWE/CVE	CWE-327
Severity	Low
Status	Open
Description	The server supports weak or deprecated TLS/SSL cipher suites and protocols, reducing the strength of encrypted communications.
Impact	Attackers may decrypt traffic, perform man-in-the-middle attacks, and expose sensitive data.
Recommendation	Disable weak ciphers and older protocols like SSLv2, SSLv3, TLS 1.0, and TLS 1.1. Use only strong ciphers with TLS 1.2 or TLS 1.3 enabled.
Proof of Concept	

Note: The below POC shows that weak TLS ciphers are used.

```
sslscan cgmsc.gov.in
Version: 2.1.5
OpenSSL 3.6.2 7 Apr 2026

Connected to 164.100.131.161

Testing SSL server cgmsc.gov.in on port 443 using SNI name cgmsc.gov.in

  SSL/TLS Protocols:
SSLv2     disabled
SSLv3     enabled
TLSv1.0   enabled
TLSv1.1   enabled
TLSv1.2   enabled
TLSv1.3   disabled
```

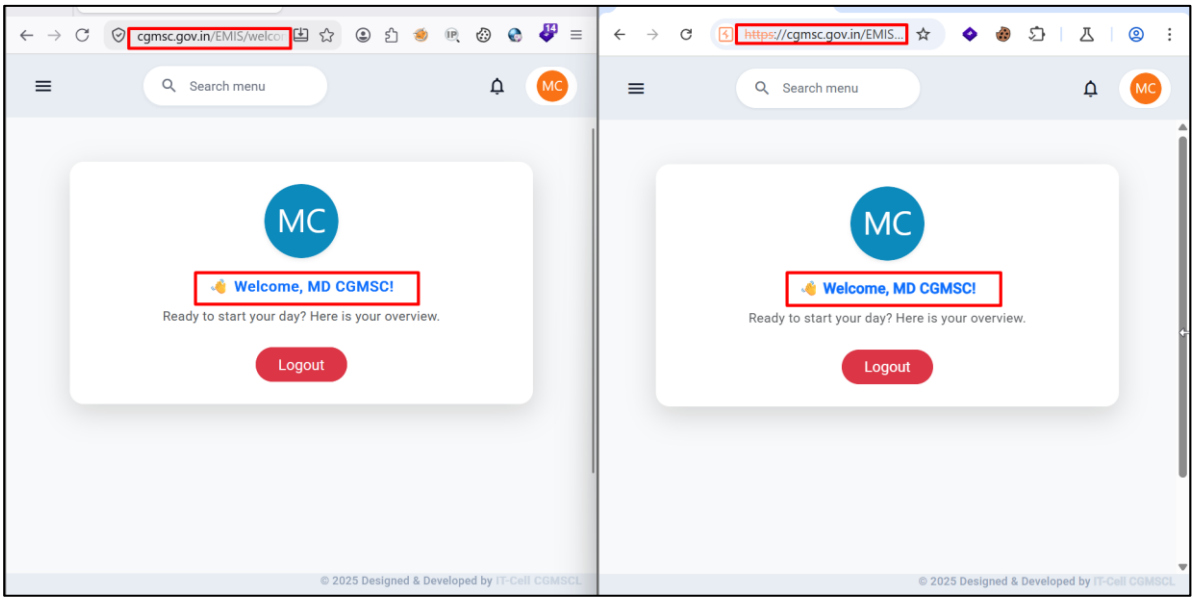
POC 1 – TLS 1 and TLS 1.1 protocols are offered.

```
 Secure Renegotiation (RFC 5746)          supported (OK)
 Secure Client-Initiated Renegotiation    not vulnerable (OK)
 CRIME, TLS (CVE-2012-4929)               not vulnerable (OK)
 BREACH (CVE-2013-3587)                   no gzip/deflate/compress/br HTTP compression (OK)  - only supplied "/ems
a" tested
 POODLE, SSL (CVE-2014-3566)              VULNERABLE (NOT ok), uses SSLv3+CBC (check TLS_FALLBACK_SCSV mitigation
below)
 TLS_FALLBACK_SCSV (RFC 7507)             Downgrade attack prevention NOT supported and vulnerable to POODLE SSL
 SWEET32 (CVE-2016-2183, CVE-2016-6329)   VULNERABLE, uses 64 bit block ciphers
 FREAK (CVE-2015-0204)                    not vulnerable (OK)
 DROWN (CVE-2016-0800, CVE-2016-0703)     not vulnerable on this host and port (OK)
                                          make sure you don't use this certificate elsewhere with SSLv2 enabled se
rvices, see
                                          https://search.censys.io/search?resource=hosts&virtual_hosts=INCLUDE&q=D
23E4462746D2853F751D5838E0954140313C408C68E98D6D6C71437407B3E43
 LOGJAM (CVE-2015-4000), experimental     VULNERABLE (NOT ok): common prime: RFC2409/Oakley Group 2 (1024 bits),
                                          but no DH EXPORT ciphers
 BEAST (CVE-2011-3389)                    SSL3: DES-CBC3-SHA
                                          TLS1: ECDHE-RSA-AES256-SHA ECDHE-RSA-AES128-SHA DHE-RSA-AES256-SHA
                                                DHE-RSA-AES128-SHA AES256-SHA AES128-SHA DES-CBC3-SHA
                                          VULNERABLE -- but also supports higher protocols  TLSv1.1 TLSv1.2 (likel
y mitigated)
 LUCKY13 (CVE-2013-0169), experimental    potentially VULNERABLE, uses obsolete cipher block chaining ciphers with
 TLS, see server prefs.
 Winshock (CVE-2014-6321), experimental   not vulnerable (OK) - GCM rollup ciphers found
 RC4 (CVE-2013-2566, CVE-2015-2808)       VULNERABLE (NOT ok): RC4-SHA RC4-MD5
```

POC 2 – The above POC shows that the application is vulnerable to BEAST.

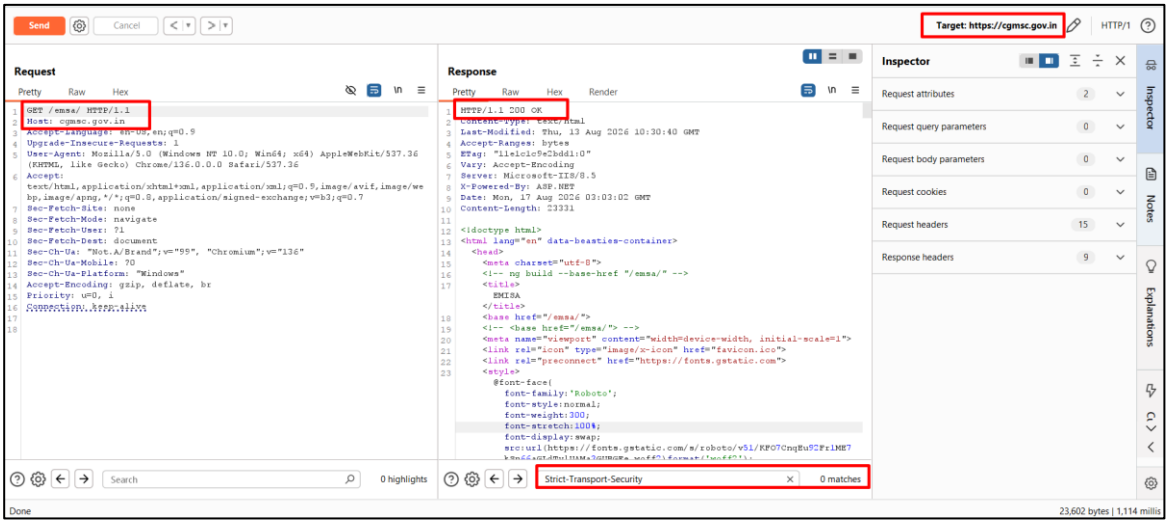
Vulnerability Point No. 10	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/EMIS/welcome
Vulnerability Name	Concurrent login
CWE/CVE	CWE-287
Severity	**Low**
Status	**Open**
Description	The application allows the same user credentials to be used for multiple active sessions simultaneously without restriction.
Impact	This increases the risk of unauthorized account usage, makes it harder to detect compromised credentials, and may enable session abuse or misuse.
Recommendation	It is recommended to limit the number of concurrent sessions per user, implement session management controls, and notify users when multiple logins are detected.
Proof of Concept	

Note: The below POC shows that application allows simultaneous logins for same user account.



Vulnerability Point No. 11	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/emsa/
Vulnerability Name	HTTP Strict-Transport-Security (HSTS) header missing
CWE/CVE	CWE-693
Severity	Low
Status	Open
Description	The application does not implement HTTP Strict-Transport-Security (HSTS), allowing browsers to access the site over unsecured HTTP connections.
Impact	Improper configuration may allow downgrade attacks, reducing the effectiveness of HTTPS enforcement.
Recommendation	HSTS should be enabled with an appropriate max-age value and include subdomains to ensure all connections are enforced over HTTPS.
Proof of Concept	

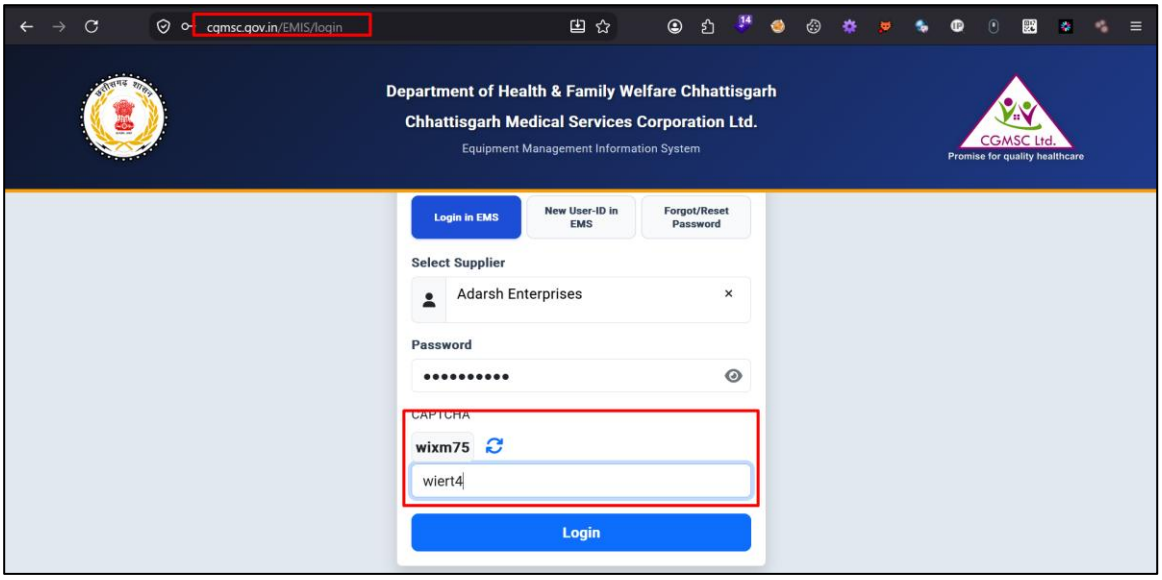
Note: The below POC shows that HTTP Strict-Transport-Security (HSTS) header is missing.



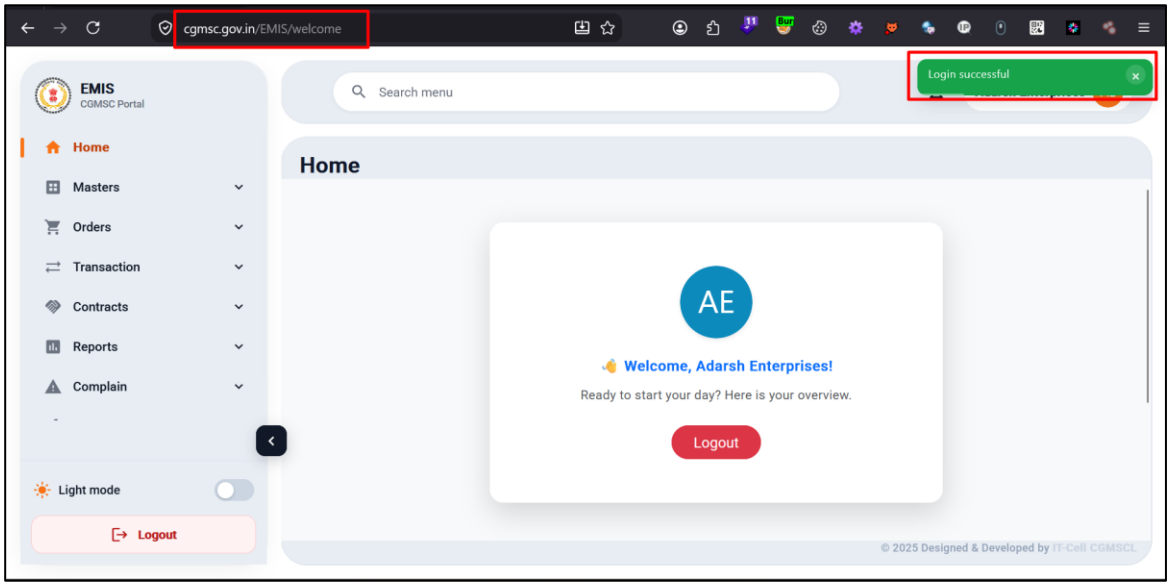
Vulnerability Point No. 12	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/EMIS/login
Vulnerability Name	Improper CAPTCHA validation
CWE/CVE	CWE-804
Severity	Low
Status	Open
Description	The application uses a CAPTCHA mechanism during the login process; however, the CAPTCHA validation is not properly enforced. The application accepts login attempts even when the CAPTCHA is incorrect or left blank, indicating that the CAPTCHA response is not being properly validated.
Impact	Weak CAPTCHA validation may reduce the effectiveness of the CAPTCHA mechanism and make it easier for automated tools or bots to bypass the intended validation. This could increase the risk of automated login attempts, credential stuffing, or brute-force attacks if other authentication controls are insufficient.
Recommendation	Implement strict, server-side CAPTCHA validation before processing authentication requests. The application should reject login attempts when the CAPTCHA is incorrect, blank, or missing. CAPTCHA verification should be performed independently on the server, with appropriate rate limiting and account protection mechanisms to prevent automated login attempts.
Proof of Concept	

Note: The below POC shows that the CAPTCHA is not validating properly.

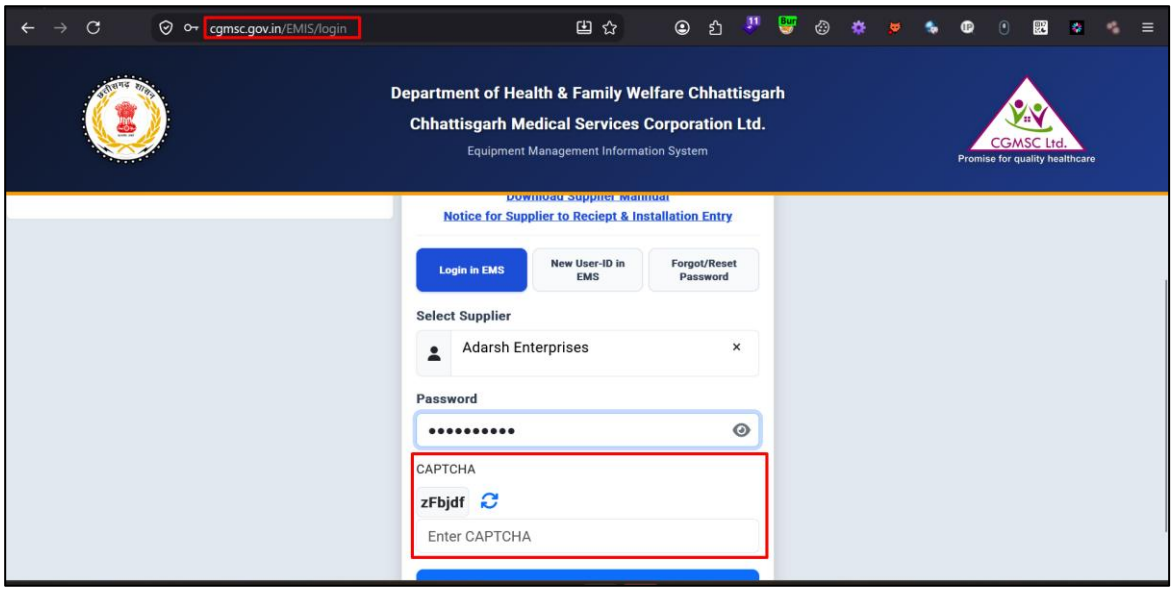
The identified Improper CAPTCHA Validation issue is applicable to the Supplier user role.



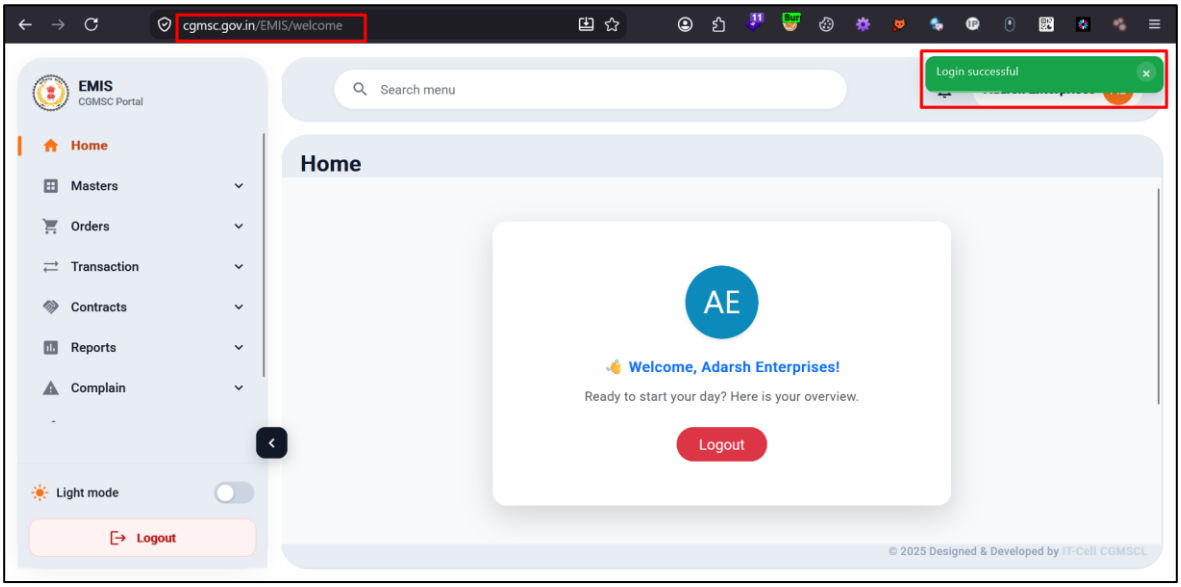
POC 1 - Enter an incorrect CAPTCHA value and click login.



POC 2 - Login was successful despite entering an incorrect CAPTCHA.



POC 3 - Enter no value in the CAPTCHA field and click login.

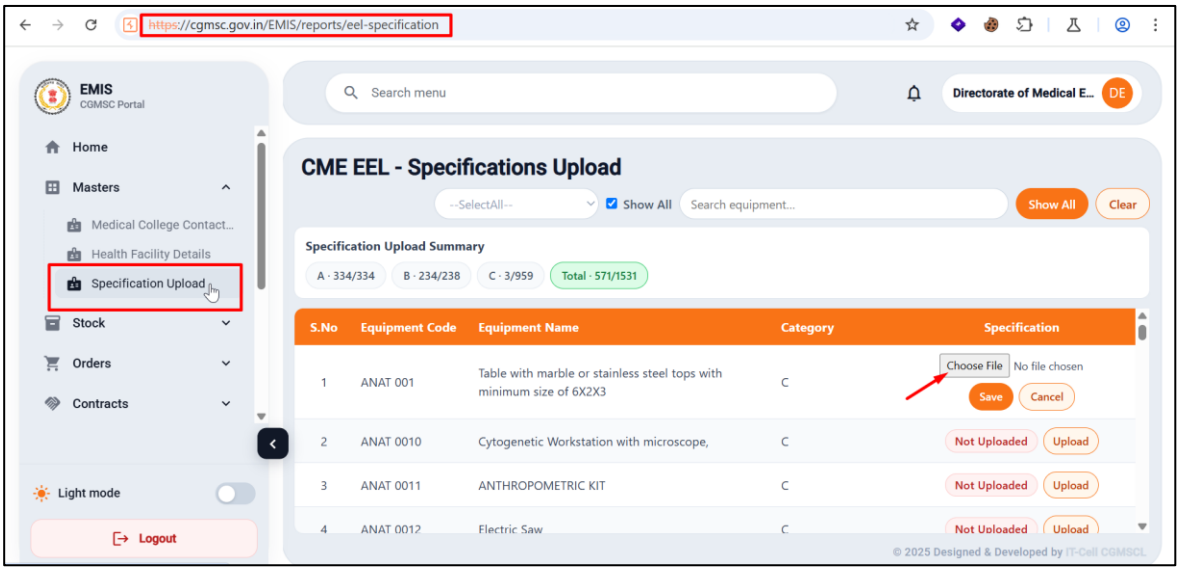


POC 4 - The application allowed successful login when the CAPTCHA field was left blank.

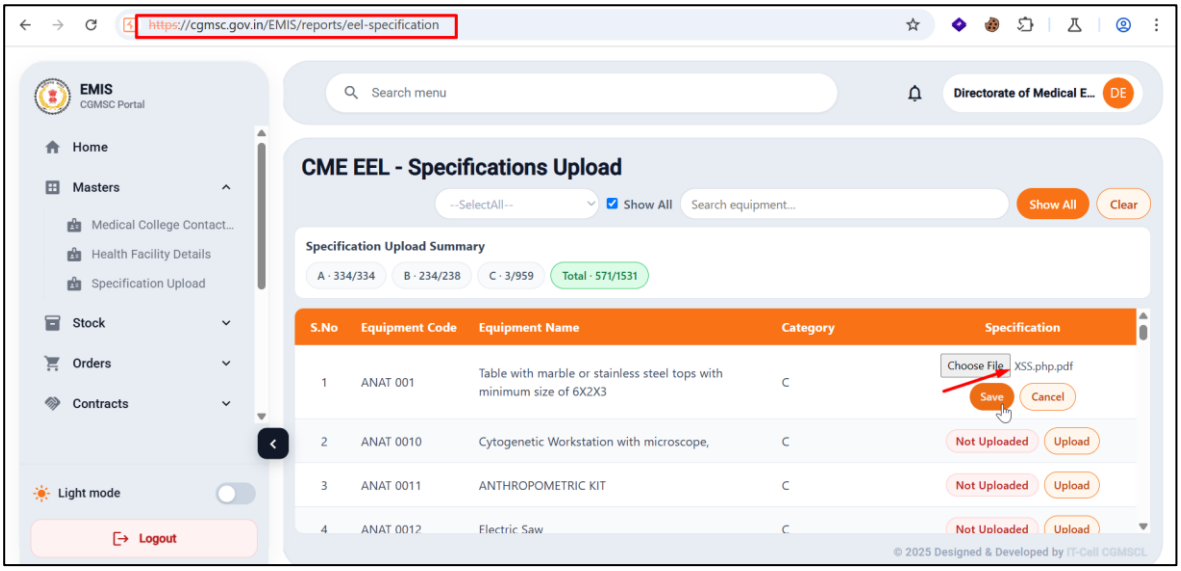
Vulnerability Point No. 13	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/EMIS/reports/eel-specification
Vulnerability Name	Unrestricted file upload
CWE/CVE	CWE-434
Severity	Low
Status	Open
Description	The application allows users to upload files without sufficient validation of file type, extension, or content. This may allow attackers to upload malicious files that could be executed by the server.
Impact	Attackers may upload malicious files to execute arbitrary code, compromise the server, steal sensitive data, or disrupt application availability.
Recommendation	Validate file type, extension, MIME type, and file content using a whitelist. Store uploaded files outside the web root, disable execution permissions, and scan files for malware before storage.
Proof of Concept	

Note: The below POC shows the unrestricted file upload.

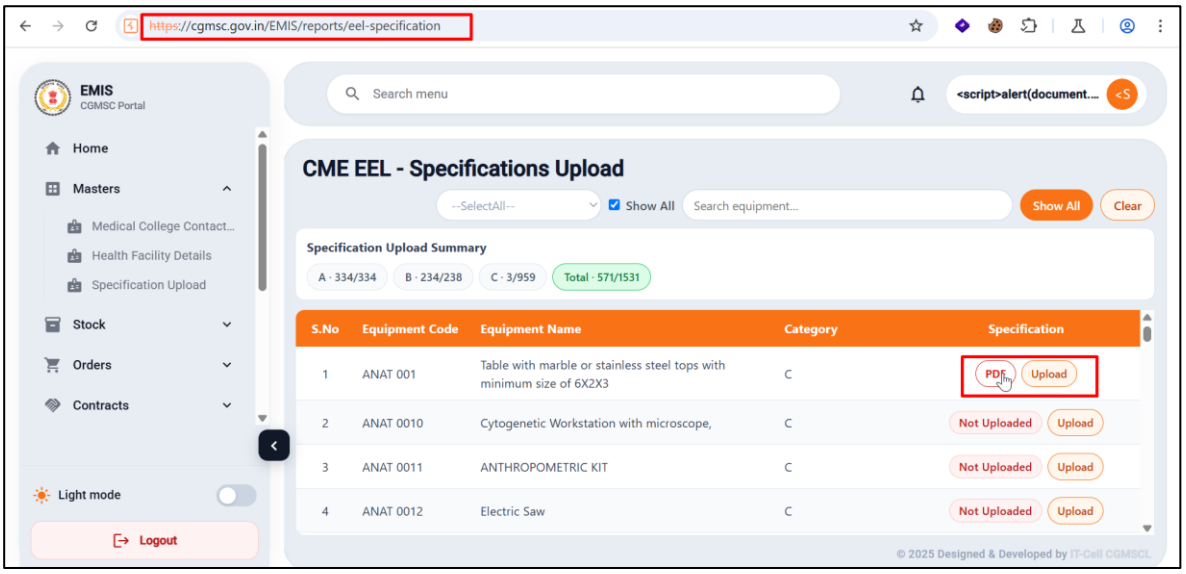
The identified Unrestricted File Upload issue is applicable to the file upload functionality under the Admin role when the Directorate is selected as CIMS Medical College.



POC 1 - Navigate to Masters → Specification Upload and click Choose File for the required equipment specification.



POC 2 - Upload a double extension file.



POC 3 - The file was uploaded successfully.

Vulnerability Point No. 14	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/emsa/
Vulnerability Name	HTTP OPTIONS method enabled
CWE/CVE	CWE-200
Severity	**Info**
Status	**Open**
Description	The application server responds to HTTP OPTIONS requests. This method reveals supported HTTP methods and can provide information about the server configuration.
Impact	While not directly exploitable, attackers can gather information about allowed HTTP methods and use it to plan further attacks.
Recommendation	Restrict or disable the OPTIONS method unless required. Implement proper server configuration to limit information disclosure.
Proof of Concept	

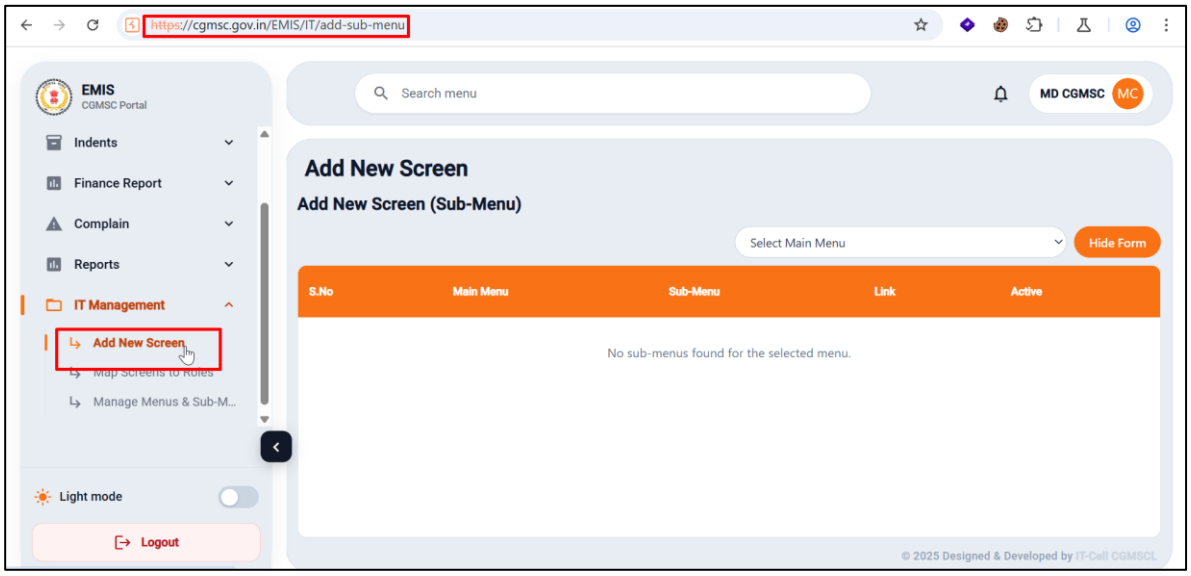
Note: The below POC shows that HTTP OPTIONS method is enabled, exposing supported methods.



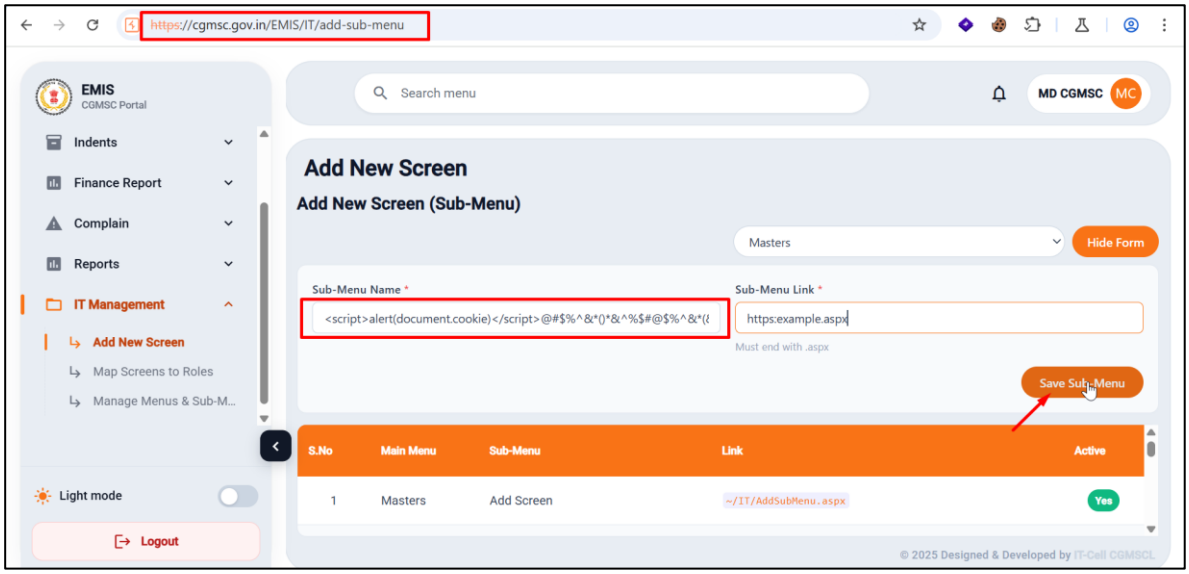
Vulnerability Point No. 15	
Affected URL/ Application/Point / Path	https://cgmsc.gov.in/EMIS/IT/add-sub-menu https://cgmsc.gov.in/EMIS/StoreHome
Vulnerability Name	Improper input validation
CWE/CVE	CWE-20
Severity	Info
Status	Open
Description	The application does not validate or sanitize user inputs in certain requests. While no active exploit was observed, improper input validation may allow injection attacks, unexpected behavior, or system errors if not handled correctly.
Impact	Potential for attacks such as XSS, SQL injection, command injection, or other input-based exploits in the future.
Recommendation	Implement proper input validation and sanitization on both client and server sides. Apply whitelisting for acceptable input formats. Use parameterized queries and encoding for user-supplied data.
Proof of Concept	

Note: The below POC shows that application is not properly validating user inputs.

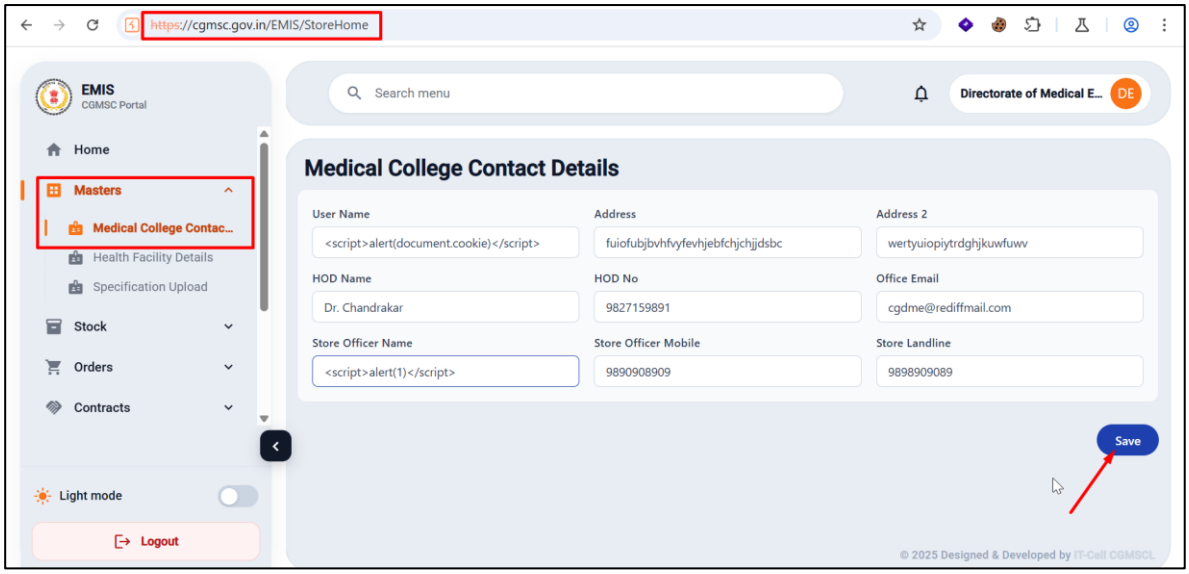
The identified Improper Input Validation issue is applicable to the admin role and its sub-roles, including Administrator, Directorate, and CGMSCL.



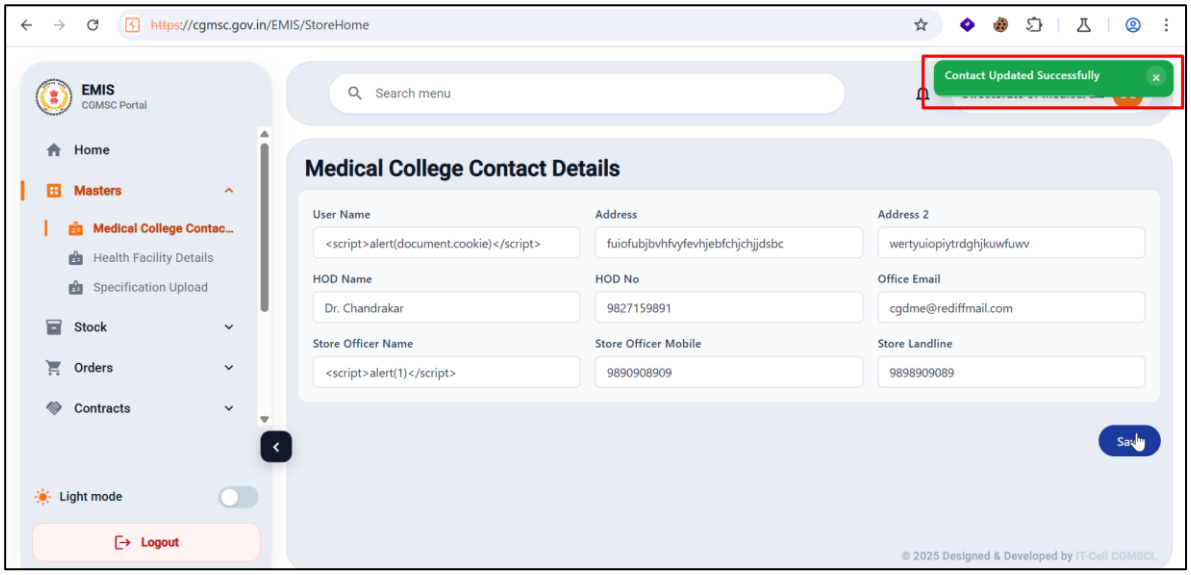
POC 1 - Click IT Management → Add New Screen.



POC 2 - Enter the XSS payload in the Sub-Menu Name field and click Save Sub-Menu.



POC 3 - Enter the XSS payload in the relevant input field and click the Save button.



POC 4 - The contact details were updated successfully after submitting the XSS payload.

********** **End of the report** **********